Firewalls

Introduction

- seen evolution of information systems
- now everyone want to be on the Internet
- and to interconnect networks
- has persistent security concerns
  - can’t easily secure every system in org
- need "harm minimisation"
- a **Firewall** usually part of this

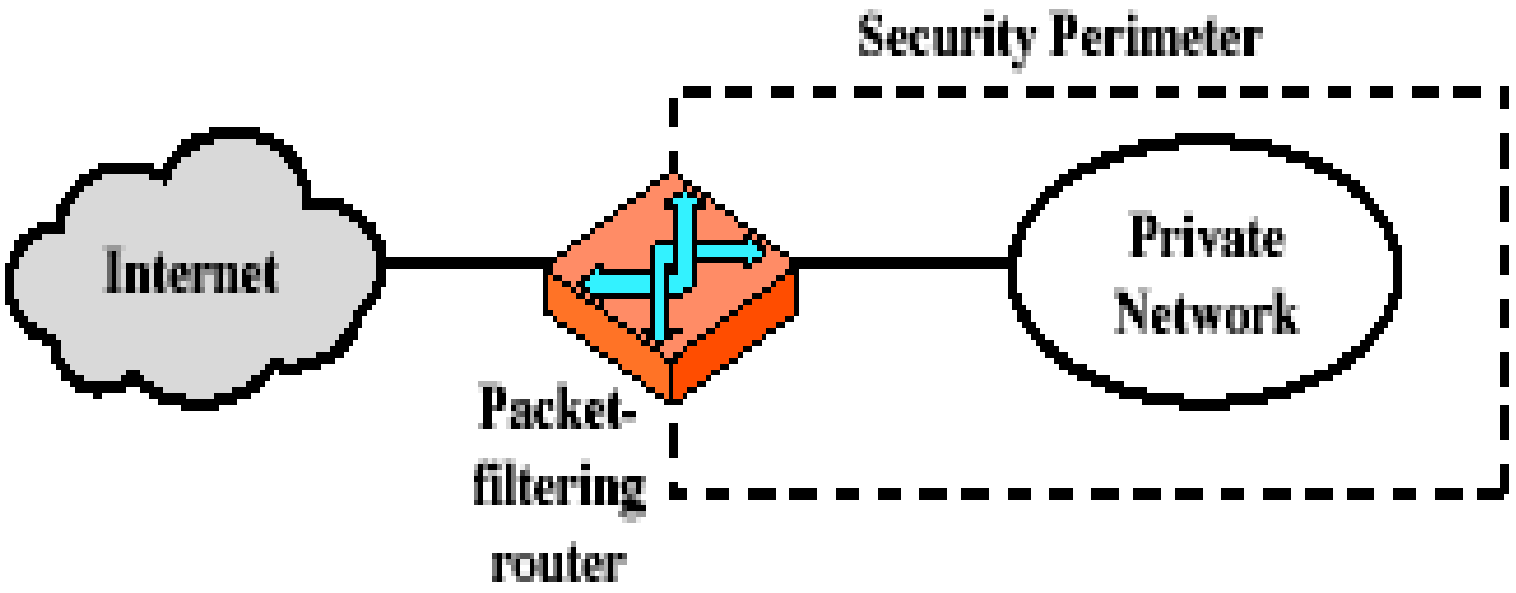
What is a Firewall?

- a **choke point** of control and monitoring
- interconnects networks with differing trust
- imposes restrictions on network services
  - only authorized traffic is allowed
- auditing and controlling access
  - can implement alarms for abnormal behavior
- is itself immune to penetration
- provides **perimeter defence**

Firewall Limitations

- cannot protect from attacks bypassing it
  - eg sneaker net, utility modems, trusted organisations, trusted services (eg SSL/SSH)
- cannot protect against internal threats
  - eg disgruntled employee
- cannot protect against transfer of all virus infected programs or files
  - because of huge range of O/S & file types

Firewalls – Packet Filters



(a) Packet-filtering router

Firewalls – Packet Filters … Contd.

- simplest of components
- foundation of any firewall system
- examine each IP packet (no context) and permit or deny according to rules
- hence restrict access to services (ports)
- possible default policies
  - that not expressly permitted is prohibited
  - that not expressly prohibited is permitted

Firewalls – Packet Filters … Contd.

Packet-Filtering Examples

A

action	ourhost	port	theirhost	port	comment
block	*	*	SPIGOT	*	we don't trust these people
allow	OUR-GW	25	*	*	connection to our SMTP port

B

action	ourhost	port	theirhost	port	comment
block	*	*	*	*	default

C

action	ourhost	port	theirhost	port	comment
allow	*	*	*	25	connection to their SMTP port

D

action	src	port	dest	port	flags	comment
allow	{our hosts}	*	*	25		our packets to their SMTP port
allow	*	25	*	*	ACK	their replies

E

action	src	port	dest	port	flags	comment
allow	{our hosts}	*	*	*		our outgoing calls
allow	*	*	*	*	ACK	replies to our calls
allow	*	*	*	>1024		traffic to nonservers

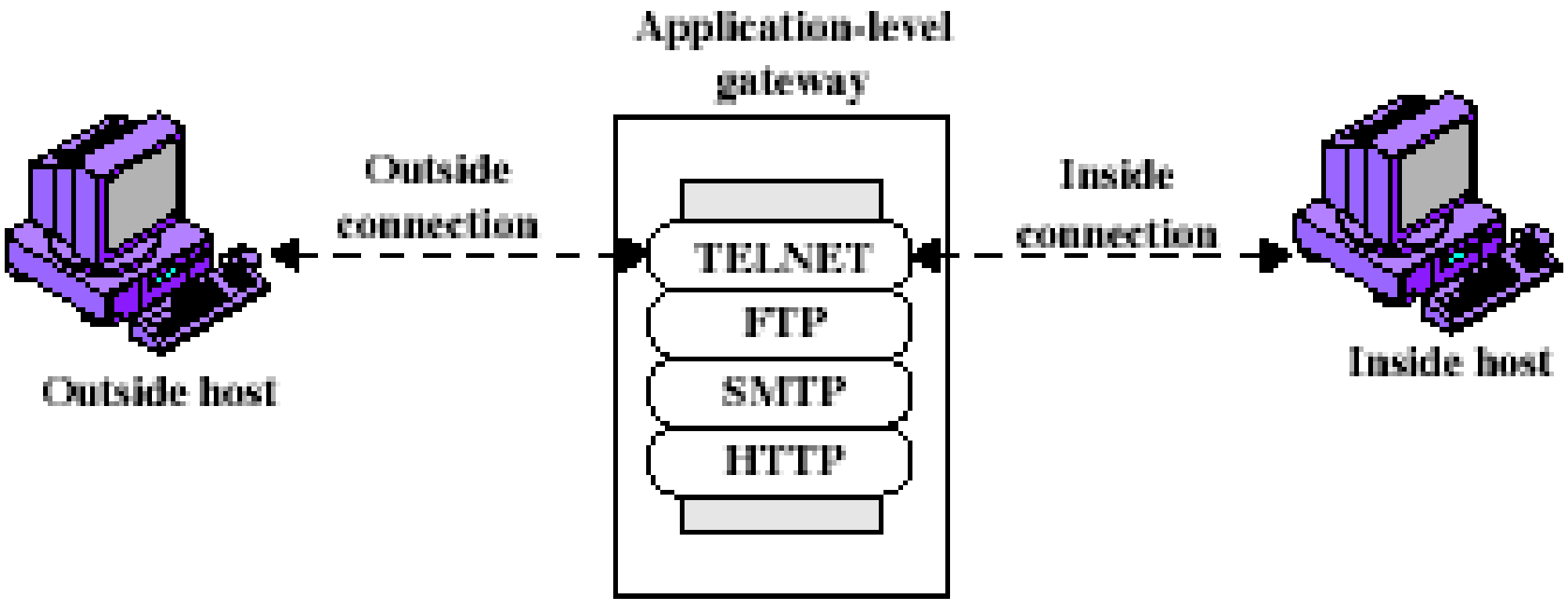
Attacks on Packet Filters

- IP address spoofing
  - fake source address to be trusted
  - add filters on router to block
- Source routing attacks
  - attacker sets a route other than default
  - block source routed packets
- Tiny fragment attacks
  - split header info over several tiny packets
  - either discard or reassemble before check

Firewalls – Stateful Packet Filters

- examine each IP packet in context
  - keeps tracks of client-server sessions
  - checks each packet validly belongs to one
- better able to detect bogus packets out of context

Firewalls - Application Level Gateway (or Proxy)

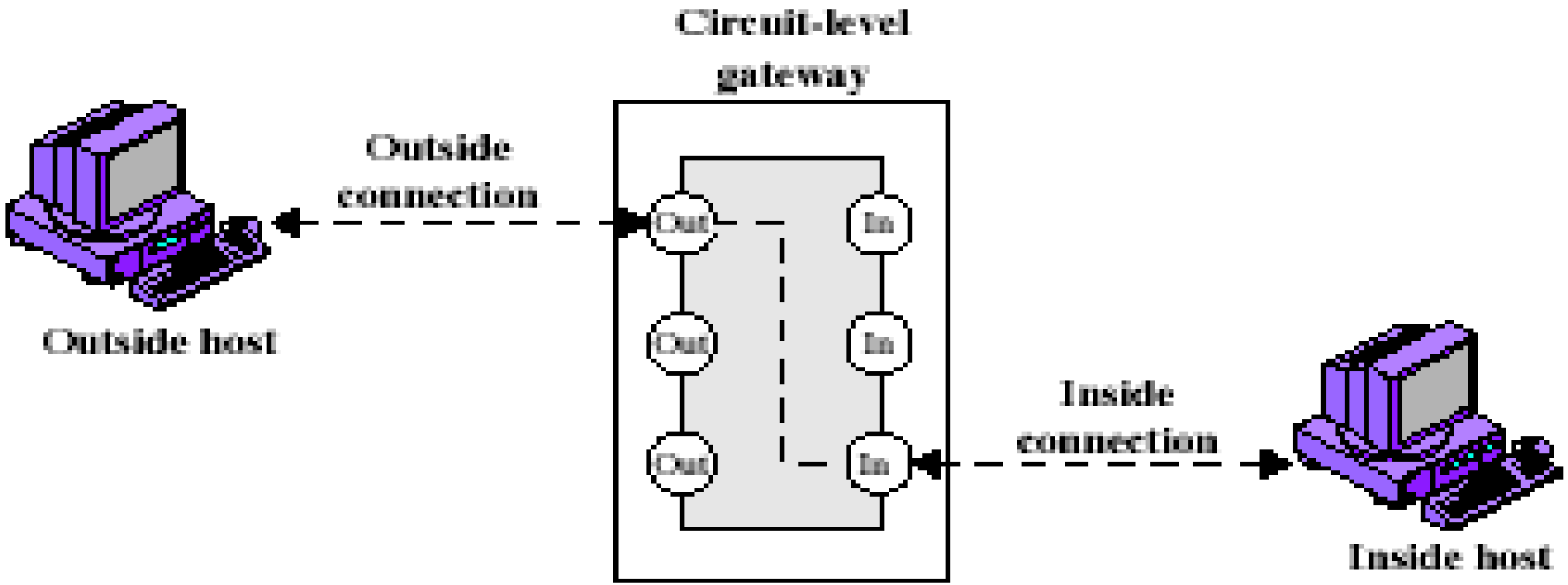


(b) Application-level gateway

Firewalls - Application Level Gateway (or Proxy)

- use an application specific gateway / proxy
- has full access to protocol
  - user requests service from proxy
  - proxy validates request as legal
  - then actions request and returns result to user
- need separate proxies for each service
  - some services naturally support proxying
  - others are more problematic
  - custom services generally not supported

Firewalls - Circuit Level Gateway



(c) Circuit-level gateway

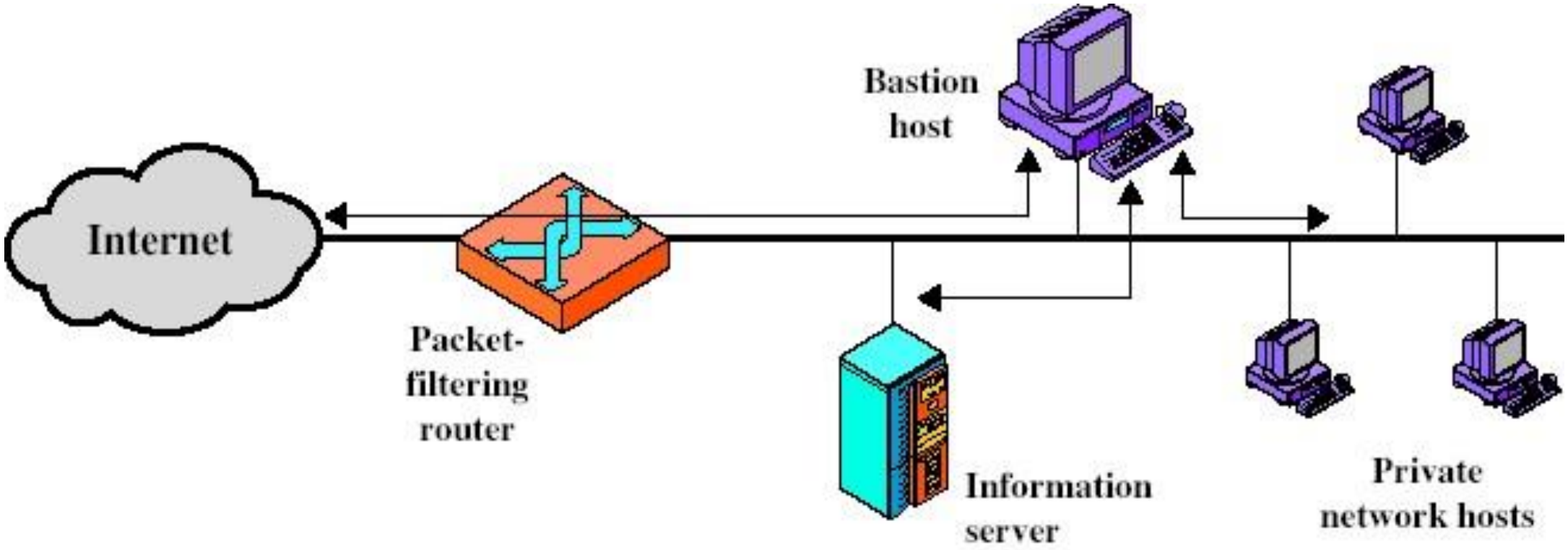
Firewalls - Circuit Level Gateway … Contd.

- relays two TCP connections
- imposes security by limiting which such connections are allowed
- once created usually relays traffic without examining contents
- typically used when trust internal users by allowing general outbound connections
- SOCKS commonly used for this

Bastion Host

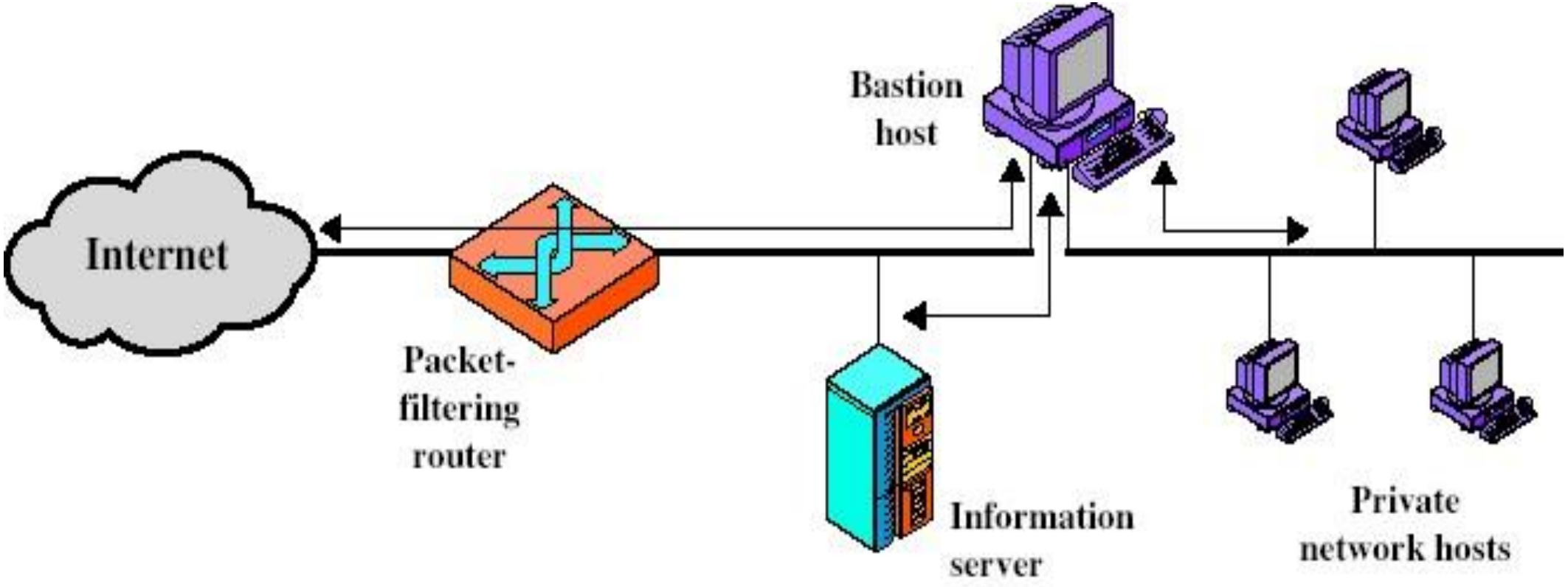
- highly secure host system
- potentially exposed to "hostile" elements
- hence is secured to withstand this
- may support 2 or more net connections
- may be trusted to enforce trusted separation between network connections
- runs circuit / application level gateways
- or provides externally accessible services

Firewall Configurations



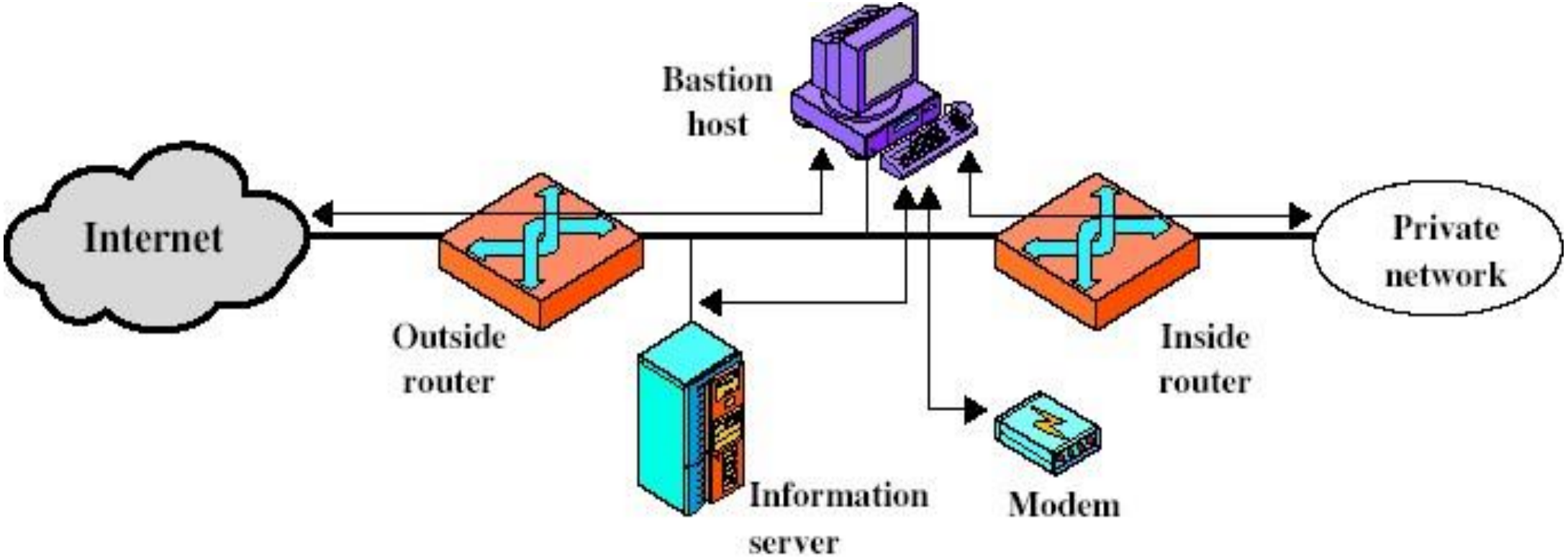
(a) Screened host firewall system (single-homed bastion host)

Firewall Configurations … Contd.



(b) Screened host firewall system (dual-homed bastion host)

Firewall Configurations … Contd.



(c) Screened-subnet firewall system

Access Control

- given system has identified a user
- determine what resources they can access
- general model is that of access matrix with
  - **subject** - active entity (user, process)
  - **object** - passive entity (file or resource)
  - **access right** – way object can be accessed
- can decompose by
  - columns as access control lists
  - rows as capability tickets

Access Control Matrix

	Program1	• • •	SegmentA	SegmentB
Process1	Read Execute		Read Write	
Process2				Read
•				
•				
•				

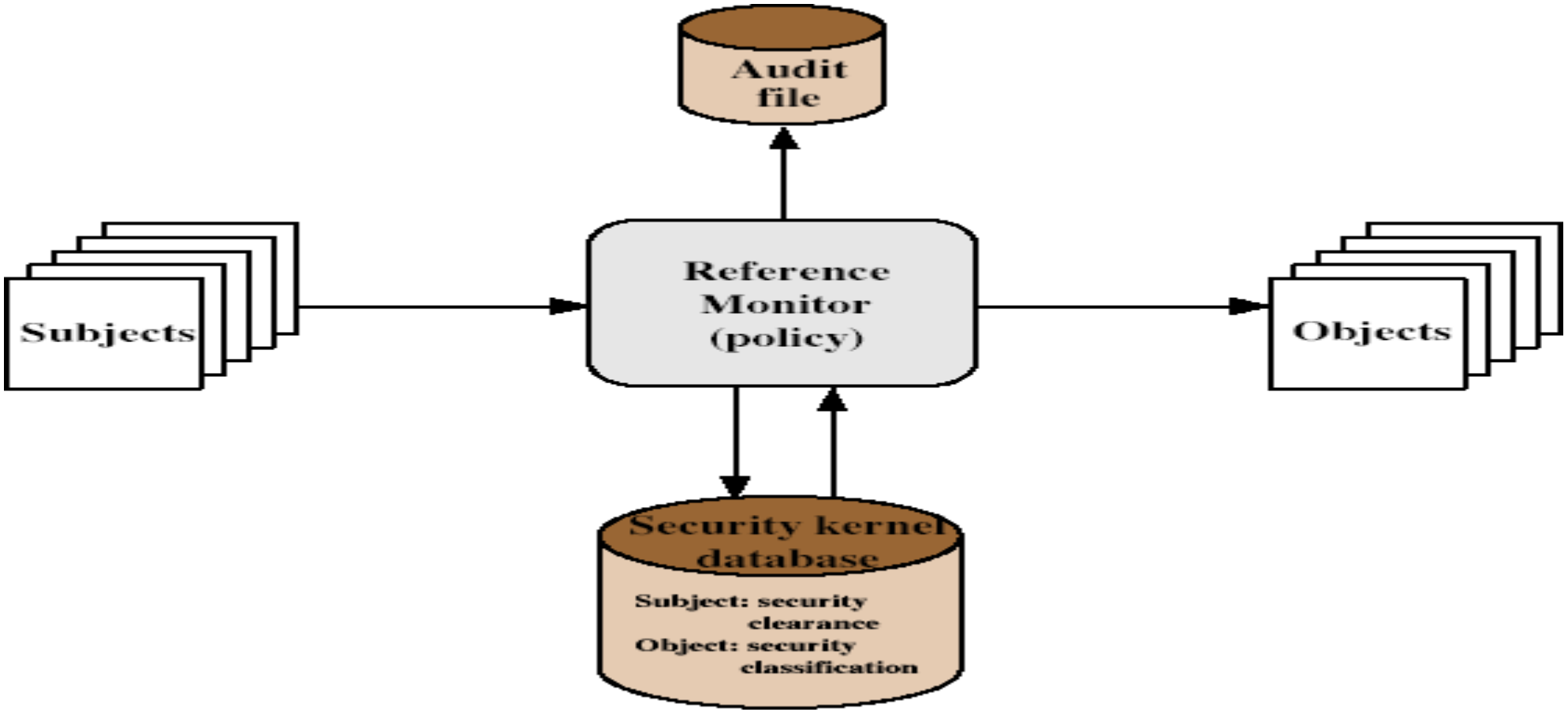
Trusted Computer Systems

- information security is increasingly important
- have varying degrees of sensitivity of information
  - cf military info classifications: confidential, secret etc
- subjects (people or programs) have varying rights of access to objects (information)
- want to consider ways of increasing confidence in systems to enforce these rights
- known as multilevel security
  - subjects have **maximum** & **current** security level
  - objects have a fixed security level **classification**

Bell LaPadula (BLP) Model

- one of the most famous security models
- implemented as mandatory policies on system
- has two key policies:
- **no read up** (simple security property)
  - a subject can only read/write an object if the current security level of the subject dominates (>=) the classification of the object
- **no write down** (*-property)
  - a subject can only append/write to an object if the current security level of the subject is dominated by (<=) the classification of the object

Reference Monitor



Evaluated Computer Systems

- governments can evaluate IT systems
- against a range of standards:
  - TCSEC, IPSEC and now Common Criteria
- define a number of “levels” of evaluation with increasingly stringent checking
- have published lists of evaluated products
  - though aimed at government/defense use
  - can be useful in industry also